

NorthStream Technologies

Configuration Baseline Checklist for Web Server Infrastructure

Course: Cybersecurity Legislation and Compliance Assessments

Student: HASSANI Mohammad Salem

Date: January 25, 2026

Instructor: Asen Grozdanov

COMPONENT 1: PLATFORM SELECTION & JUSTIFICATION

Platform: Nginx v1.24.0+ on Ubuntu 22.04 LTS (Extended support until April 2032)

Role: Public-facing SaaS web tier (8–10 servers in AWS us-east-1)

Why Nginx?

1. **Lightweight architecture** – 4–8 MB vs. Apache 10–20 MB; minimal attack surface
2. **Proven production stability** – 40,000+ concurrent users; high-traffic SaaS proven
3. **Native reverse proxy** – Built-in load balancing to PostgreSQL backends
4. **CIS Benchmark support** – v1.1.0 (2023) aligned with NIST SP 800-123
5. **Rapid security patching** – Critical CVE fixes within 48 hours

Why Ubuntu 22.04 LTS?

Extended support through April 2032 aligns with PIPEDA Principle 7 requirement for systems maintained with security patches throughout operational lifetime. LTS ensures:

- Stable kernel/OpenSSL versions with 5+ years of security maintenance
 - Enterprise regulatory alignment satisfying GDPR Article 32 "state-of-the-art" requirement
 - Compliance audit defensibility – courts recognize LTS as evidence of reasonable care
-

COMPONENT 2: FRAMEWORK & REFERENCES

Primary Framework: CIS Benchmarks v1.1.0 for Nginx

- Community-consensus standard (NSA, CISA, Microsoft, Google, AWS)

- L1/L2 leveling enables risk-based prioritization
- Automated scanning support (OpenSCAP, CIS-CAT Pro)

Secondary References:

1. NIST SP 800-123 – Guide to General Server Security
2. OWASP Web Server Security Guidelines
3. Ubuntu Security Guide (USG) – CIS hardening profiles
4. Nginx Official Documentation – <https://docs.nginx.com/>

COMPONENT 3: CONFIGURATION BASELINE CHECKLIST (18 Items)

CATEGORY A: Network Service Hardening (4 Items)

Item	Configuration	CIS Ref	Priority
A-1	HTTPS-only – Disable HTTP port 80; redirect 301	Nginx 6.1	L1
A-2	TLS 1.2+ only – Disable SSLv2/SSLv3/TLS 1.0/1.1	Nginx 4.2	L1
A-3	Strong ciphers – ECDHE with forward secrecy; A+	Nginx 4.3	L1
A-4	Remove defaults – Delete nginx.html; disable stub_status	Nginx 2.1	L1

Verification: `curl -I http://northstream.com` (301 redirect), testssl.sh (no legacy TLS), SSL Labs (Grade A+), `curl /nginx_status` (404)

A-1: HTTPS-Only Traffic

nginx.conf:

```
server {
listen 80;
return 301 https://server_name$request_uri;
}
server {
listen 443 ssl http2;
ssl_protocols TLSv1.2 TLSv1.3;
}
```

Compliance: PIPEDA Principle 7, GDPR Article 32, NIST CSF PR.DS-2

Verify: `curl -I http://northstream.com` → 301 HTTPS redirect

A-2: Disable Insecure TLS Protocols

nginx.conf:

```
ssl_protocols TLSv1.2 TLSv1.3;  
ssl_prefer_server_ciphers on;  
ssl_session_timeout 1d;  
ssl_session_cache shared:SSL:50m;
```

Verify: `testssl.sh https://northstream.com` (no SSLv3/TLS 1.0/1.1)

A-3: Strong Cipher Suites with Perfect Forward Secrecy

nginx.conf:

```
ssl_ciphers 'ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-  
GCM-SHA256:  
ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-RSA-AES256-GCM-SHA384:  
ECDHE-ECDSA-CHACHA20-POLY1305:ECDHE-RSA-CHACHA20-POLY1305';  
ssl_ciphers_order on;
```

Verify: `SSL Labs test` → Grade A+; `echo | openssl s_client -connect northstream.com:443 | grep Cipher`

A-4: Remove Default Content & Unused Modules

Commands:

```
rm /usr/share/nginx/html/index.html  
rm /usr/share/nginx/html/50x.html  
rm -rf /etc/nginx/sites-enabled/default
```

nginx.conf:

```
location /nginx_status { deny all; }
```

Verify: `curl /nginx_status` → 404 Not Found

CATEGORY B: Authentication & Access Controls (3 Items)

Item	Configuration	CIS Ref	Priority
B-1	SSH hardening – Disable root; key-based auth	SSH 5.2	L1
B-2	HTTP auth – Protect /admin with bcrypt; 20+ char passwords	Nginx 5.1	L1

B-3	Rate limiting – 5 req/min on /login; 429 response	Nginx 3.5	L2
-----	---	-----------	-----------

B-1: SSH Hardening

/etc/ssh/sshd_config:

```
PermitRootLogin no
PubkeyAuthentication yes
PasswordAuthentication no
MaxAuthTries 3
ClientAliveInterval 300
X11Forwarding no
```

Key Management:

```
ssh-keygen -t ed25519 -f ~/.ssh/id_ed25519 -N "passphrase_20+_chars"
```

Verify: `ssh root@server` → fails; `ssh -i key admin@server` → succeeds

B-2: HTTP Basic Authentication

nginx.conf:

```
location /admin {
    auth_basic "Restricted Access";
    auth_basic_user_file /etc/nginx/.htpasswd;
}
```

Create credentials:

```
htpasswd -c /etc/nginx/.htpasswd adminuser
chmod 0640 /etc/nginx/.htpasswd
```

Verify: `curl /admin` → 401; `curl -u user:pass /admin` → 200

B-3: Rate Limiting

nginx.conf:

```
limit_req_zone $binary_remote_addr zone=auth_limit:10m rate=5r/m;

location /login {
    limit_req zone=auth_limit burst=5 nodelay;
}
```

Verify: 10 rapid login attempts → requests 6–10 return 429 Too Many Requests

CATEGORY C: Cryptographic Controls (4 Items)

Item	Configuration	CIS Ref	Priority
C-1	HSTS header – max-age=31536000; includeSubDomains; preload	Nginx 4.5	L1
C-2	X-Content-Type-Options – nosniff	Nginx 6.4	L1
C-3	X-Frame-Options – SAMEORIGIN	Nginx 6.3	L1
C-4	Content-Security-Policy – restrictive CSP	Nginx 6.5	L2

C-1: HSTS Header

nginx.conf:

```
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;
```

Verify: `curl -I https://northstream.com | grep Strict-Transport-Security`

C-2: X-Content-Type-Options

nginx.conf:

```
add_header X-Content-Type-Options "nosniff" always;
```

Verify: `curl -I https://northstream.com | grep X-Content-Type-Options`

C-3: X-Frame-Options

nginx.conf:

```
add_header X-Frame-Options "SAMEORIGIN" always;
```

Verify: `curl -I https://northstream.com | grep X-Frame-Options`

C-4: Content Security Policy

nginx.conf:

```
add_header Content-Security-Policy "default-src 'self'; script-src 'self'
https://trusted-cdn.com; object-src 'none'; form-action 'self';" always;
```

Verify: CSP validator (<https://csp-evaluator.withgoogle.com/>)

CATEGORY D: Logging, Monitoring, Auditing (3 Items)

Item	Configuration	CIS Ref	Priority
D-1	Access logging – format with IP, method, status, time; 90-day rotation	Nginx 7.1	L1
D-2	Error logging – warn level; mask credentials	Nginx 7.2	L1
D-3	SIEM forwarding – Filebeat/rsyslog; <5s latency; NTP sync	Nginx 7.3	L1

D-1: Access Logging

nginx.conf:

```
log_format main '$remote_addr - remote_user [time_local] "request"' status
body_bytes_sent "http_user_agent" $request_time';
```

```
access_log /var/log/nginx/access.log main buffer=32k flush=5s;
```

/etc/logrotate.d/nginx:

```
/var/log/nginx/*.log {
daily
rotate 90
compress
create 0640 www-data www-data
}
```

Verify: 90-day retention: `find /var/log/nginx/ -name "access.log.*" -mtime +90 | wc -l → 0`

D-2: Error Logging

nginx.conf:

```
error_log /var/log/nginx/error.log warn;
```

```
map $request_uri loggableaccess_log/var/log/nginx/  
access.logmainif =loggable;
```

Verify: Credentials NOT in logs: `grep "password\|api_key" /var/log/nginx/access.log` → empty

D-3: SIEM Forwarding

/etc/filebeat/filebeat.yml:

filebeat.inputs:

- type: log
paths:
 - /var/log/nginx/access.log
 - /var/log/nginx/error.log

output.elasticsearch:

hosts: ["siem-cluster:9200"]

index: "nginx-logs-%{+yyyy.MM.dd}"

NTP Sync:

`timedatectl set-ntp true`

Verify: SIEM dashboard shows logs; latency <5s; `timedatectl status` → "NTP synchronized: yes"

CATEGORY E: Application-Level Hardening (2 Items)

Item	Configuration	CIS Ref	Priority
E-1	Hide server banner – <code>server_tokens off</code>	Nginx 5.3	L1
E-2	Request limits – <code>client_max_body_size 10M</code> ; disable TRACE/DELETE	Nginx 5.4	L2

E-1: Suppress Server Banner

nginx.conf:

`server_tokens off`;

`add_header Server "WebServer" always`;

Verify: `curl -I https://northstream.com | grep Server` → "WebServer"
(not nginx version)

E-2: Request Size Limits

nginx.conf:

```
client_max_body_size 10M;
```

```
if (request_method ! ~ GET|HEAD|POST|PUT) {  
    return 405;  
}
```

Verify: POST >10M → 413; TRACE → 405

CATEGORY F: Patch Management & Integrity (2 Items)

Item	Configuration	CIS Ref	Priority
F-1	Patch schedule – unattended-upgrades; critical within 7 days	Nginx 8.1	L1
F-2	File integrity – AIDE; monitor /etc/nginx/*; daily cron	Nginx 8.2	L2

F-1: Patch Management

Install unattended-upgrades:

```
apt-get install unattended-upgrades
```

/etc/apt/apt.conf.d/50unattended-upgrades:

```
Unattended-Upgrade::Automatic-Reboot "true";  
Unattended-Upgrade::Automatic-Reboot-Time "03:00";
```

Verify: systemctl status unattended-upgrades → active; cat /var/log/unattended-upgrades/unattended-upgrades.log → recent patches

F-2: File Integrity Monitoring

Install AIDE:

```
apt-get install aide aide-common  
aideinit  
mv /var/lib/aide/aide.db.new.gz /var/lib/aide/aide.db.gz
```

/etc/cron.daily/aide-check:

```
aide --check >> /var/log/aide/aide.log 2>&1  
if [ $? -ne 0 ]; then
```



```
mail -s "AIDE Alert" secops@northstream.com < /var/log/aide/aide.log  
fi
```

Verify: `aide --check` → "No changed files"; modify config → detected immediately

COMPONENT 4: COMPLIANCE MAPPING

Control ID	PIPEDA	NIST CSF	GDPR 32	Quebec 25
A-1,2,3,C-1	P7 (Encryption)	PR.DS-2	Encrypt transit	Art 14
B-1,2,3	P7 (Access)	PR.AC-1,2	Access control	Art 15
C-2,3,4	P7 (Integrity)	PR.DS-2	Integrity	Art 14
D-1,2,3	P7 (Audit)	DE.CM-1	Detect breach	Art 16
E-1,2	P7 (Surface)	PR.IP-1	Minimize risk	Art 14
F-1,2	P7 (Current)	PR.IP-1	Up-to-date	Art 14

Regulatory Context:

- **PIPEDA Principle 7** – "appropriate safeguards" for 1,800+ Canadian customers + 250 staff
- **GDPR Article 32** – "state-of-the-art" measures for 150 EU customers
- **Quebec Law 25** – Information Security Program (Articles 14–18)
- **NIST CSF 2.0** – Protect, Detect, Respond functions

COMPONENT 5: IMPLEMENTATION CHECKLIST

Prerequisites

- ☐ Ubuntu 22.04 LTS fully patched (kernel, OpenSSL)
- ☐ Nginx 1.24.0+ compiled with SSL module
- ☐ Valid SSL/TLS certificates with SAN
- ☐ NTP enabled: `timedatectl set-ntp true`
- ☐ SIEM infrastructure accessible (CloudWatch, Splunk, ELK)
- ☐ SSH bastion configured; admin users have keys (no passwords)

Operational Impacts & Mitigation

Item	Impact	Mitigation	Effort
HSTS	May block clients months if misconfigured	Test Staging 7 days; start max-age=300	4 hrs
Rate limiting	May impact legitimate API bursts	Monitor SIEM; tune burst 5–20	8 hrs
Strict CSP	May break third-party integrations	Audit scripts; allowlist with docs	16 hrs
AIDE checks	Increases CPU/I/O nightly	Schedule 2–4 AM UTC; incremental	2 hrs
Kernel patches	Requires reboot; service interruption	Config Reboot-Time "03:00"; rolling (2/week)	6 hrs

Exception Process

If unable to implement baseline item:

1. Document: Item ID, business justification, compensating controls, risk assessment
2. Obtain: CISO & Privacy Officer sign-off with date
3. Schedule: Quarterly re-assessment; target removal timeline

Example: Legacy API requires 50+ login req/min → IP-allowlist + SIEM alerts (>100 failed/hr) + read-only access + TLS 1.2+ = compensating controls

Quarterly Maintenance Schedule

1. **CIS Benchmark updates** – Monitor CIS advisory mailing list
2. **Nginx CVEs** – Check NVD & Nginx security advisories
3. **NIST updates** – Review CSF/SP 800-series
4. **Regulatory changes** – OPC (PIPEDA), CNIL (GDPR), CAI (Law 25)
5. **Threat landscape** – Evaluate new attack patterns

Update Rollout: Validate Staging (2 weeks) → Approval (1 week) → Rolling Production (2 servers/week)

CRITICAL REFLECTION

1. Specificity vs. Flexibility:

Exact nginx.conf directives enable objective auditor verification. Parameterized values (log retention "min 90 days," rate limit "burst=5") accommodate

deployment scenarios. Terraform/Ansible templates enable consistent rollout across 8–10 servers.

2. Risk-Based Top 5 Priorities:

- (1) **A-1 + C-1** – HTTPS + HSTS (encryption mandatory; regulatory violation if missing)
- (2) **A-2 + A-3** – TLS 1.2+ + strong ciphers (eliminates Poodle, BEAST)
- (3) **D-1 + D-3** – Logging + SIEM (critical for Law 25 24-hour breach notification)
- (4) **F-1** – Patch management (eliminates known exploitable vulnerabilities)
- (5) Remaining items are L2 (enhanced) controls

3. Verification Challenge – Rate Limiting (B-3):

Automated scanners cannot reliably trigger limits. Manual verification: Spin up Staging replica; script 10 login attempts; verify requests 6–10 return 429. Effort: ~2 hours quarterly.

4. Baseline Evolution:

Monthly CVE monitoring + quarterly update cycle. CIS reviews → Staging (2 weeks) → Security team approval → rolling Production (2 servers/week). Git version control with CISO sign-off before merge. Balance security urgency (Critical CVEs within 7 days) vs. operational stability.

5. Organizational Factors:

Beyond technical controls, NorthStream requires:

- (1) **Governance** – Change Advisory Board (CISO, IT Ops, Privacy Officer approval for deviations)
 - (2) **Training** – Annual 2-hour staff training on GDPR/PIPEDA/Law 25
 - (3) **Incident response** – SOC monitors 24/7; 5 min response P1, 15 min P2
 - (4) **Vendor accountability** – Include baseline in AWS/Okta/GitHub contracts; annual SOC 2 reports
 - (5) **Leadership** – CEO messaging: baseline compliance is non-negotiable; budget 2–3 FTE for maintenance
-

REFERENCES

[1] NorthStream Compliance Assessment Plan (Project Task 4); PIPEDA Principles 4.7 & 8; Quebec Law 25 Articles 3–18; OPC breach notification guidance

[2] CIS Benchmarks for Nginx v1.1.0 (<https://www.cisecurity.org/cis-benchmarks>); Nginx Official Documentation (<https://docs.nginx.com/>)

[3] NIST Cybersecurity Framework 2.0 (<https://www.nist.gov/cyberframework>); NIST SP 800-123; GDPR Articles 32–33; Mozilla SSL Config (<https://ssl-config.mozilla.org/>)
